S&P Capital IQ PRO

Grupo Bimbo, S.A.B. de C.V. | ESG Scores Raw Data

BMV:BIMBO A (MI KEY: 4276592; SPCIQ KEY: 877906; TCUID: 53231)

Additional Disclosure

Year: Methodology Year: 2021
Question: Information Security Governance
Include Modeled Scores : Yes

Information Security Governance

Question

Does the company have governance mechanisms to oversee its information security activities?

Rationale

Due to the current trend of digitization, including but not limited to cloud computing, online market places and payments etc., it is crucial that access to network, IT systems and data is assured at all times. As a result, lower than agreed upon system performance or service disruptions can result in higher costs and reputational risk for companies. The main risks stem from technical failure, human error, malicious attacks, weather events, natural disasters or terrorist attacks. Managing such risks, including contingency plans, is crucial to ensuring business continuity.

Over the past decade, the number of information security breaches has grown exponentially with some attacks reaching unprecedented scale and the cyber threat landscape continues to grow and evolve, abusing existing and new technologies and exploiting vulnerable users. These incidents and the related costs have shown that information security/cybersecurity has become a financially material issue which must be diligently managed to protect corporate value. The costs of cyberattack are manifold and can impact the company in different ways. Internal costs are operational costs and relate to dealing with cybercrime and incidence prevention. External costs include the consequences of the cyber-attack such as the loss or theft of sensitive information, operations' disruption, fines and penalties, infrastructure damage or revenue losses due to loss of customers. Thus, ensuring the security and resilience of netw

All boards should have the ability to understand cyber threats and assess management's capability of dealing with Cyber-related issues according to the National Association of Corporate Directors (NACD). However also senior executives, like CISO, CSO or CIO, must have the necessary leadership, operational and strategic skills to understand and face the risk. A cyber-risk committee would have the role to encourage both the board and executives to give cyber-security issues a high priority and to prioritize them with strong oversight.

The question focuses on whether the company has the appropriate governance to prevent IT system failures ad major information security / cybersecurity incidents.

Performance Summary	
Question Level Company Performance	
Question Weight	
Year-on-Year Change	
Industry Average Score	
Industry Highest Score	

The question layout and the company's verified information is provided below. No information is shown if the company did not provide any information or if it opted out of sharing non-public information.

Additional Question Guidance & Information Display

▼ Additional Question Guidance & Information Display

Key Definitions

CISO: A chief information security officer (CISO) is the senior-level executive in an organization responsible for establishing and maintaining the organization's vision, strategy, and program to ensure information assets and technologies are well protected. As the highest ranking cyber security executive, the chief information security officer (CISO), or alternatively the Chief Information Officer (CIO), is responsible for establishing and maintaining the enterprise strategy and processes that protect information assets.

CSO: A Chief Security Officer (CSO) is the senior-level executive responsible for the physical security of a company, including its communication and business systems. CSO's responsibility is to protect people, assets, technology, and infrastructure.

Cybersecurity: Cybersecurity is the body of technologies, processes and practices designed to protect networks, systems, computers, programs and data from attack, damage or unauthorized access (according to SEC).

Experience: Relevant experience could be past experience in implementation of IT, information security or cybersecurity or operational responsibility for IT as a senior executive of a company. In addition for Board Member, non-technical experience as a senior executive of an IT company (such as SVP Marketing, Sales etc.) is not valid. Academic experience in IT is not considered relevant.

Information security: The protection of information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction in order to provide confidentiality, integrity, and availability (according to NIST).

Information System: Applications, services, information technology assets, or other information handling components (according to ISO).

IT security: IT security is the process of implementing measures and systems designed to securely protect and safeguard information utilizing various forms of technology. IT security is thus considered a bit broader than cybersecurity.

Important note: Throughout the whole criterion we always refer to IT security, cybersecurity or information security according to the definitions above. For the appraisal of the criterion we will treat "IT security", "information security" and "cybersecurity" equally.

Data requirements

Disclosure requirements for partially public question: Additional credit will be granted for relevant publicly available evidence covering:

- The board member's membership in the committee which oversees cyber security strategy
- The role or function within or reporting directly to the Executive Management team responsible for overseeing cybersecurity within the company

For **executive management responsibility**, please indicate which role or function within or reporting directly to the Executive Management team is responsible for overseeing cybersecurity within the company. The best practice is to have a CISO or CSO as part of the Executive Management team or reporting directly to it. In case another function has responsibility for IT security/cybersecurity and is part of or reporting directly to the Executive Management team, please select the second or third option accordingly.

References

GRI 102-19 and GRI 102-20 are relevant for this question.

Data View

QUESTION LEVEL INPUT	COMPANY ANSWER
Engagement of board of directors and executive management in the information security/ cybersecurity strategy and review process	Applicable
The board has responsibility for cybersecurity strategy and monitoring	-
Name of board member responsible for cybersecurity/ information security strategy	Not answered
Board member's membership in the committee which oversees cyber security strategy	Not answered
Executive Management has responsibility for cybersecurity strategy and monitoring	YES
Role or function of executive management member which oversees cyber security strategy	CTO / CIO

Questionnaire

Are the board of directors and executive management engaged in the information security /cybersecurity strategy and review process?

1. ●
   Yes, we have either a director on the board with relevant background in IT engaged on the cybersecurity strategy process and/or someone in the Executive Management team who oversees the company's cybersecurity strategy:
   1. ☐
      Board Responsibility
      Please indicate the Board member who oversees the cybersecurity strategy together with his/her experience and indicate this person's membership in the committee responsible for the oversight of cybersecurity. Please attach supporting evidence and indicate if it is available in the public domain.

Board Member	**Please indicate the Board member's membership in the committee which oversees cyber security strategy**
Name of board member: Not answered Relevant experience and previously held positions:	1. ○ Cybersecurity / information security committee 2. ○ Risk committee 3. ○ Audit committee 4. ○ Not known

   2. ☑
      Executive Management Responsibility
      Please indicate which role or function within or reporting directly to the Executive Management team is responsible for overseeing cybersecurity within the company. Please attach supporting evidence and indicate if it is available in the public domain.
      1. ○
         Chief Information Security Officer (CISO) / Chief Security Officer (CSO)
      2. ●
         Chief Technology Officer (CTO) / Chief Information Officer (CIO) or similar
      3. ○
         CEO / COO / CRO or similar with clear responsibility for IT security/cybersecurity
      4. ○
         We do not have anyone who oversees cybersecurity in the executive management team
      5. ○
         Not known
2. ○
   No, the board of directors is not engaged in the cybersecurity strategy process or the responsible person does not have relevant IT background.
3. ○
   Not applicable. Please provide explanations in the comment box below.
4. ○
   Not known

Confidential additional comments

Use the text field below only in the following cases: (i) to describe significant changes in data or calculation methodology compared to last year's submission, (ii) to explain why a question is not applicable to your company's business model, (iii) to explain if your data deviates from the unit or format requested, or (iv) to provide supporting notes on translations of non-English references.